

SQL Injection Exploitation – Vuln Bank Web Application

Name: Aswana Ashok

Date: 19/10/25

Assessment Type: Web Application Penetration Testing – SQL Injection Analysis

Objective

The objective of this assessment is to identify, exploit, and understand SQL Injection (SQLi) vulnerabilities within the *Vuln Bank* application hosted in a controlled Docker environment. This practical exercise demonstrates how insecure coding practices in database queries can be exploited to gain unauthorized access and manipulate application data.

Information Sources

- TryHackMe – *SQL Injection Fundamentals*
 - OWASP Top 10 – Injection (A03:2021)
 - Vuln Bank Lab Documentation
 - Nmap / Burp Suite / Browser DevTools
-

Methodology & Execution

Task 1: Environment Setup

- The vulnerable *Vuln Bank* web application was launched successfully using Docker.
 - Verified access to <http://localhost:5000> and confirmed all modules (Login, Loan Approval, AI Chatbot).
-

Task 2: Authentication Testing

Performed input fuzzing on the login page. Initial credential attempts returned standard error responses, confirming server-side SQL query execution.

Task 3: Exploiting SQL Injection

Payload Used:

' OR 1=1--

Explanation:

This payload converts the SQL statement from

```
SELECT * FROM users WHERE username='admin' AND password='password';
```

to

```
SELECT * FROM users WHERE username='admin' OR 1=1--';
```

Since 1=1 is always true, authentication checks are bypassed.

Result:

- Successfully gained administrative access.
 - Confirmed via access to the admin dashboard.
-

Task 4: Post-Exploitation (Access Validation)

Using the admin dashboard, a pending loan request for a test user was approved to confirm privilege escalation worked correctly.

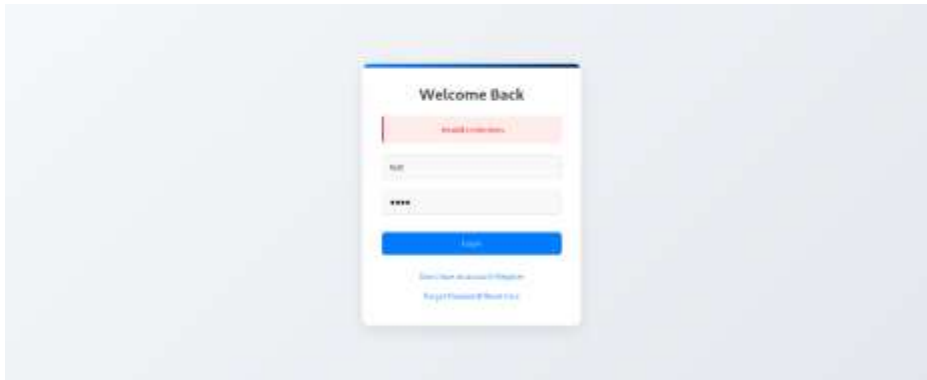
Task 5 : Used Burp Suite Repeater to Create New Admins

I used Burp Suite's Repeater to intercept and tamper with user-management requests and successfully created/converted a normal user into an administrator.

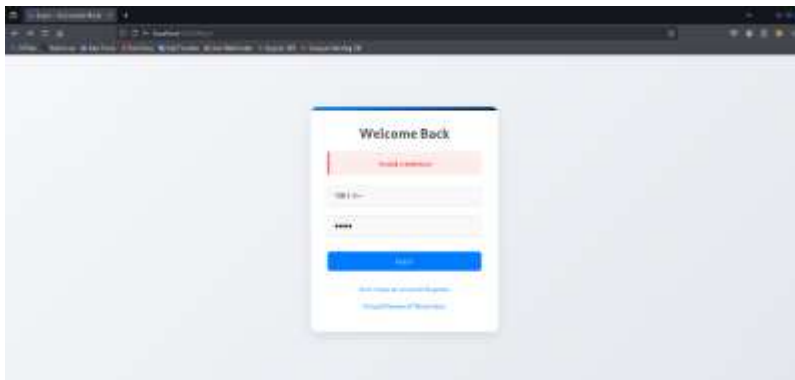
The app trusts client-side parameters and/or lacks server-side role enforcement. By replaying and modifying the HTTP request (role, user_type, is_admin, etc.) in Repeater, the server accepted the change and elevated a user to admin.

Results and Conclusion

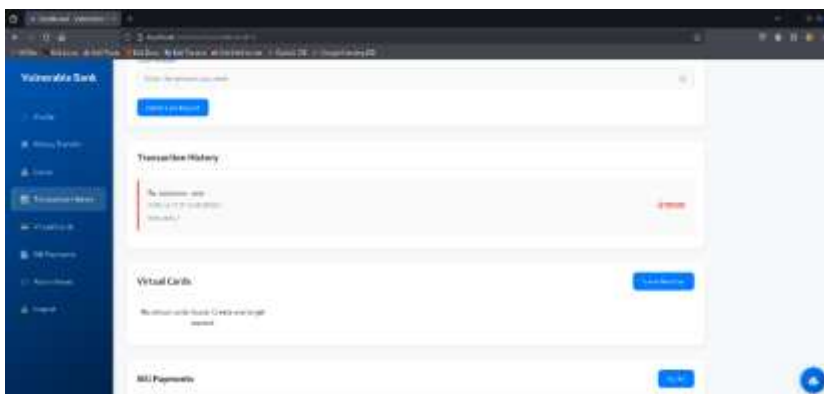
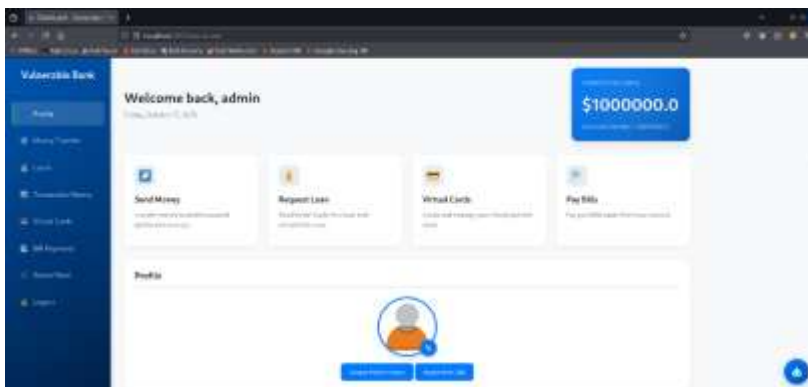
- **Critical flaws** in authentication logic allowed complete admin takeover.
- **Improper input validation** led to financial logic abuse.



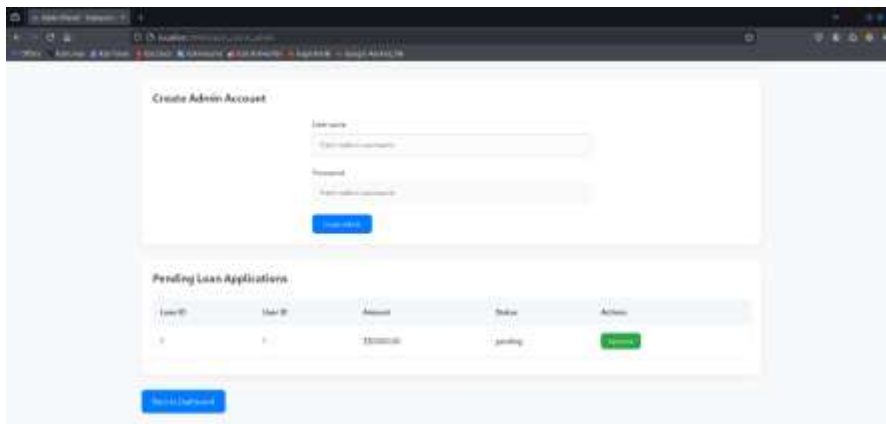
3. SQL Injection Payload Entry



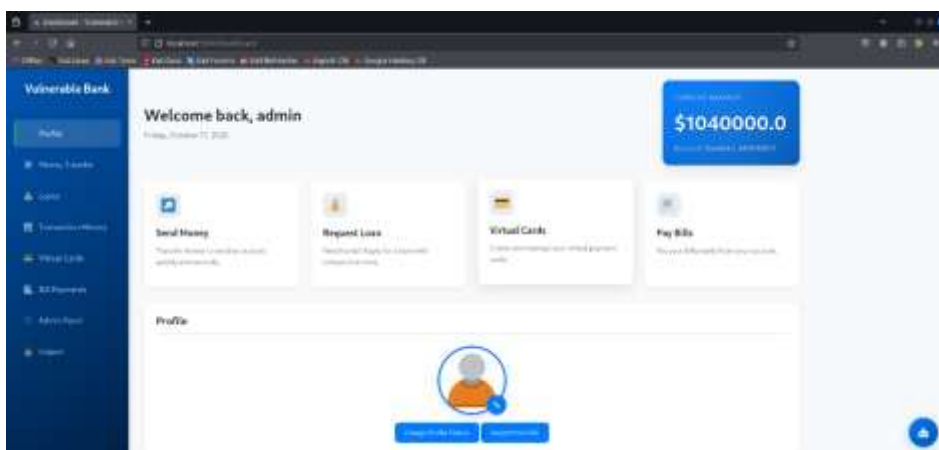
4. Admin Dashboard Access



5. Loan Approval Confirmation



6. Balance Manipulation Proof



7. Extra : Used repeater in burp suite to make new admins

